# UNIT III RECONNAISSANCE

Harvester – Whois – Netcraft – Host – Extracting Information from DNS – Extracting Information from E-mail Servers – Social Engineering Reconnaissance; Scanning – Port Scanning – Network Scanning and Vulnerability Scanning – Scanning Methodology – Ping Sweep Techniques – Nmap Command Switches – SYN – Stealth – XMAS – NULL – IDLE – FIN Scans – Banner Grabbing and OS Finger printing Techniques.

### 3.1 Harvester

Harvester is an information-gathering tool that is built by the guys at edge security and is included by default in Kali Linux. The goal of this tool is to find and gather all email
addresses, subdomains, hosts, ports, employee names, and banners that can provide information about the
target. This tool is intended to help Penetration testers in the early stages of the penetration test in order to understand the customer footprint on the Internet. It is also useful for anyone that wants to know what an attacker can see about their organization.
**Note:** But the unique part is that Harvester doesn't use any advanced algorithms to crack passwords, t est firewalls, or sniff data on networks. Instead, it gathers public information available on the internet automatically.

**# Why do we gather information?**
Well, in any pentesting task, the first thing you need to do is know your target. The more information we have about the target, the easier it is to hack the target victim. We can find useful information like t he email address to target for phishing or which domains are vulnerable on the company network. We can also use this information for social engineering attacks which are at the top of every hacker's arsenal By using this tool critical information that companies knowing or unknowingly disclose can be obtained legally and used to understand the target.
This tool is designed to help the penetration tester on an earlier stage; it is effective, simple and easy to use. The sources supported are:
1. Google – emails, subdomains
2. Google profiles – Employee names
3. Bing search – emails, subdomains/hostnames, virtual hosts
4. Pgp servers – emails, subdomains/hostnames
5. LinkedIn – Employee names
6. Exalead – emails, subdomains/hostname

**# Usage of The Harvester Tool in linux with examples:**
1. For finding Email Ids:
Command:

:

```
┌──(komal㉿kali)-[~]
└─$ theHarvester -d cvcc.edu  -l 100 -b google
```

Result:

```
[*] Target: cvcc.edu

        Searching 0 results.
        Searching 100 results.
[*] Searching Google.

[*] No IPs found.

[*] Emails found: 5
____________________

dvann@cvcc.edu
last@cvcc.edu
sbc@cvcc.edu
wbunch@cvcc.edu
xx@cvcc.edu

[*] Hosts found: 3
___________________

my.cvcc.edu:152.27.33.19
mycatalog.cvcc.edu:18.215.95.201, 3.208.11.34
www.cvcc.edu:75.103.71.197
```

2. For gather employee names and then save it to file:
Command:

```
┌──(komal㉿kali)-[~]
└─$ theHarvester -d cvcc.edu  -l 100 -b Linkedin -f Myresults
```

**3.2 Whois**

Whois is a widely used Internet record listing that identifies who owns a domain and how to get in contact with them.

'Whois' is the name of the protocol that is used to interrogate the servers operated by Regional Internet Registries, which hold information about every resource (IP address or domain name) registered on the Internet. The information that you can obtain about a resource is: Name of the owner company.

**Whois Lookup**

In this section, we are going to have a look at is Whois Lookup. It is a protocol that is used to find the owners of internet resources, for example, a domain, a server, an IP address. In this, we are not actually hacking, we are just retrieving information from a database about owners of stuff on the internet. For example, if we wanted to register a domain name like zaid.com we have to supply information about the person who is signing in like address, and then the domain name will be stored in our name and people will see that Zaid owns the domain name. That is all we are going to do.

**3.3 Netcraft**

**Netcraft** is a company that specializes in providing internet services and security solutions, primarily through web hosting and online security products. It is best known for its web hosting and site analytics services, as well as for identifying and tracking cybersecurity threats.

Here are some of the key aspects of Netcraft:

1. **Internet Security and Fraud Protection**: Netcraft offers cybersecurity services, including anti-phishing and anti-fraud protection. It helps organizations protect their websites from online threats and attacks.
2. **Web Hosting Data**: The company runs the **Netcraft Web Server Survey**, which is a widely used tool for analyzing the web hosting infrastructure of websites worldwide. It tracks the number of active websites, types of servers they use, and other key metrics about the hosting environment.
3. **SSL Certificates and Encryption**: Netcraft is involved in SSL certificate management, providing organizations with encryption services to ensure secure communication over the internet.
4. **Website Analytics**: Netcraft's surveys and analytics can provide insight into the popularity of websites, the technologies they use, and trends in the hosting industry.
5. **Historical Data**: Netcraft maintains extensive historical data related to the internet's infrastructure, allowing for trend analysis and deep dives into how the internet has evolved over time.

### 3.4 Host

a **host** typically refers to any device or machine that is connected to a network and can be identified, interacted with, or attacked. **Host reconnaissance** (also known as **host discovery** or **network reconnaissance**) is the process of identifying active hosts (computers, servers, or other devices) on a network. This step is crucial for security professionals and ethical hackers when performing a security assessment or penetration test.

Host reconnaissance can involve several techniques and tools to gather information about a target system or network. Some of the common methods used in reconnaissance are:

1. Ping Sweep:

- A ping sweep is a simple method to discover which devices are live on a network. By sending ICMP Echo requests (pings) to a range of IP addresses, the attacker or security professional can determine which hosts respond, indicating they are active.

2. Port Scanning:

- Tools like **Nmap** (Network Mapper) are used to scan for open ports on a host. By identifying open ports, an attacker can identify potential services running on the target and explore vulnerabilities. A host may be running a web server on port 80, an FTP service on port 21, or a database on port 3306, for example.

3. Banner Grabbing:

- Banner grabbing involves connecting to open ports and capturing the banner information that is displayed. Many services (like web servers or FTP servers) send identifying information when a connection is established. This can provide information about the software version running on the host, which can be useful for finding known vulnerabilities.

4. DNS Interrogation:

- DNS (Domain Name System) reconnaissance can help identify hosts associated with a domain. Tools like **dig** or **nslookup** can query DNS servers for information about the domain, including IP addresses, mail servers, and other relevant details.

5. Traceroute:

- **Traceroute** is used to determine the path data takes to reach a target host. This can help identify the physical route of the network traffic, including intermediate devices and potential network bottlenecks.

6. OS Fingerprinting:

- By analyzing the responses from a host to various requests, it is possible to determine the operating system (OS) running on the target machine. Nmap, for instance, includes OS fingerprinting features that allow attackers to infer whether the host is running Windows, Linux, or another operating system based on network behavior.

7. Shodan:

- **Shodan** is a search engine for the internet of things (IoT) and networked devices. It indexes devices connected to the internet and provides information about their IP addresses, open ports, and vulnerabilities. Shodan is often used in reconnaissance to locate vulnerable or exposed hosts on the internet.

8. Netcraft:

- Netcraft, as previously mentioned, offers a range of tools for gathering information about hosts, especially from a web server perspective. It can identify the hosting provider, web technologies in use, and the server's location, among other data.

Host Reconnaissance in Penetration Testing:

In a **penetration test**, reconnaissance is one of the first steps taken to gather as much information as possible about the target system without raising suspicion. By conducting a thorough host reconnaissance, the tester (or attacker) can map out the target's network, identify vulnerable hosts, and plan the next steps of the attack (such as exploiting open services or weaknesses in the host's configuration).

Legal and Ethical Considerations:

Host reconnaissance can be used for both ethical and malicious purposes. In a **penetration test** or **ethical hacking** scenario, this is done with explicit permission from the target. Unauthorized reconnaissance or scanning of networks or hosts can be illegal and is considered hacking or cyberattack activity.

Key Tools for Host Reconnaissance:

- **Nmap**: A powerful open-source tool for network discovery and security auditing.
- **Netcat**: A versatile tool for network diagnostics, which can be used to check open ports and communicate with services on remote hosts.
- **Shodan**: A search engine that indexes devices and provides reconnaissance data.
- **Masscan**: A high-speed port scanner that can scan large networks quickly.

- **Wireshark**: A network protocol analyzer that captures and inspects packets traveling through the network.
- **nslookup** / **dig**: Tools for querying DNS information.

3.5 Extracting Information from DNS

DNS servers are an attractive target for attackers and penetration testers. They regularly include data that is considered highly important to attackers. DNS is a core element of both our local networks and the Internet. With other things, DNS is responsible for the process of translating domain names to IP addresses. For humans, it is much simpler for them to remember "google.com" rather than http://75.125.95.105. But, machines prefer the reverse. DNS serves as the middleman to make this translation process. As penetration testers, it is necessary to concentrate on the DNS servers that belong to our target. The reason is simple. In order for DNS to function correctly, it needs to be aware of both the IP address and the corresponding domain name of each machine on its network. In terms of reconnaissance, obtaining full access to an organization's DNS server is like finding a pot of gold at the end of a rainbow. Or perhaps, more correctly, it is like finding a blueprint for the organization.

But in this example, the blueprint includes a complete listing of private IP addresses that belong to our target. Remember one of the key components of data gathering is to collect IP addresses that belong to the target.

**Extracting Info from DNS Servers**

Another way for pen testers to learn more about their targets is through DNS servers and records. DNS servers store a lot of useful information about their related networks, and there are a handful of tools to use for extracting valuable information about a target.

**What DNS does (or, why we care)**

DNS is part of the TCP/IP protocol suite. It's responsible for mapping user-friendly domain names (like "google.com") to an IP address (like "172.217.4.46").

A domain name server is a server with a large database of these mappings. For pen testers, accessing DNS servers provides them with a blueprint of the company's infrastructure, via a list of internal IP addresses and host names. As Engebretson notes in his book (The Basics of Hacking and Penetration Testing), DNS servers are often poorly configured or maintained, making them easy targets.

As always, only use this for legal purposes, with authorization, etc etc.

**Zone transfers**

One particularly useful source of DNS information is a zone transfer (AXFR). Because networks typically have two or more DNS servers for redundancy or load balancing, they need to communicate with each other to share their host-to-IP mappings and stay in sync.

**Host**

If we have collected host names (for a given target) in previous reconnaissance steps, we need to translate those into IP addresses for future steps. To do so, we can use host.

Host is built into most Linux systems (including Kali). I'm not sure what a Windows equivalent is, besides maybe nslookup.

To use host, type host followed by the DNS server you are trying to find an IP address for. For example:

host ns1.bluehost.com

Which returns

ns1.bluehost.com has address 162.159.24.80

**NSLookup**

Nslookup is a tool that queries DNS server for its host records. It's available for Linux (including Kali) and Windows. To use it, open up a command line and run:

nslookup

It will then show a >, and wait for you to enter in server and the IP address of the DNS server that you want to learn about (if you only have the hostname, use host as shown in the previous section to get the IP address).

server 8.8.8.8

Then, you'll have to specify the type of DNS record. There are several different types:

- A Records point to a domain or subdomain of an IP address (for example, mapping "172.217.4.46" to "google.com").
- CNAME allows a machine to be known by the hostnames specified in the CNAME record.
- MX or Mail Exchanger is for routing email to the specified email server. There are priority numbers given to specify which mail server should be contacted first.
- NS records map a domain name to their related DNS servers (i.e. google.com -> ns1.google.com, ns2.google.com, etc.)
- TXT records are for text-based info. One example might be domain ownership verification.

A full list of DNS record types can be found here, on Wikipedia.

You can either ask for all DNS record types, or specify a certain type:

set type = any

or set type = a, set type = mx, and so on. The additional servers that you find from nslookup can be added to the target list.

**3.6 Extracting information from Email Servers**

If we find an email server, this presents another opportunity to learn more about a target. Email servers must allow outside traffic in to be useful as email servers. In The Basics of Hacking and Penetration Testing, Engebretson says to send an email to the organization with an empty .bat or .exe file. The goal is to get rejected, and then inspect the rejection email for anti-virus vendor and version information, IP address of the server, software versions being used on the server, etc.

**Zone transfers**

**Dig**

If you want to attempt a zone transfer (Engebretson notes that your chances of success are pretty low), you can use dig to do so:

dig @ip_address_here example.com -t AXFR

**Fierce**

If the zone transfer doesn't work out for you, fierce can be your backup option. Fierce is a Perl-script that comes pre-installed on Kali. To use:

cd /usr/bin/

./fierce -dns example.com

Fierce will lookup DNS servers for a given domain name, attempt a zone transfer, and then perform hundreds (or thousands) of automated DNS scans for you.

-delay The number of seconds to wait between lookups.

-dns The domain you would like scanned.

-dnsfile Use DNS servers provided by a file (one per line) for reverse lookups (brute force).

-dnsserver Use a particular DNS server for reverse lookups (probably should be the DNS server of the target). Fierce uses your DNS server for the initial SOA query and then uses the target's DNS server for all additional queries by default.

-file A file you would like to output to be logged to.

-fulloutput When combined with -connect this will output everything the webserver sends back, not just the HTTP headers.

A list of command line flags can be found here.

**All together now!**

Use whois to find the DNS servers for a given website. Next, use host to translate the hostname into an IP address. Use nslookup to get the full set of related DNS records (for mail exchangers, etc).
Use dig or fierce to attempt a zone transfer, and/or look for related DNS servers.

3.7 Social Engineering Reconnaissance

**Social Engineering Reconnaissance** is the process of gathering information about individuals, organizations, or systems through human interaction and manipulation, rather than through technical means like network scanning. Social engineering is a form of psychological manipulation that exploits human behavior to gain unauthorized access to systems, sensitive data, or physical locations.

In the context of reconnaissance, **social engineering** focuses on collecting information that can be used to exploit individuals or groups, with the goal of either bypassing technical security measures or directly manipulating targets. It plays a significant role in the early stages of an attack, as attackers rely on the weaknesses of human behavior to achieve their objectives.

Key Techniques in Social Engineering Reconnaissance:

1. **Open-Source Intelligence (OSINT)**:
    - Social engineers often gather data from publicly available sources. This might include:
        - **Social Media**: Scanning platforms like Facebook, LinkedIn, Twitter, and Instagram to learn about employees, organizational structures, personal interests, or office locations.

        - **Company Websites**: Publicly available data such as staff directories, press releases, or information about projects and internal tools.
        - **Forums and Blogs**: Discussions about the company or employees, leaks, or even disgruntled employees sharing internal information.
        - **Public Records**: Government databases, WHOIS databases (for domain registration), and other records that could contain useful personal or organizational data.
2. **Phishing**:
    - **Phishing** is one of the most common forms of social engineering, where attackers send fraudulent communications (usually emails) designed to trick individuals into revealing sensitive information like login credentials, personal details, or financial information. During reconnaissance, attackers often research employees or high-level individuals to craft **targeted phishing emails** that look legitimate and trustworthy.
    - **Spear Phishing** is a more targeted version of phishing, where the attacker focuses on a specific individual or organization based on information gathered through social engineering reconnaissance.
3. **Pretexting**:
    - Pretexting involves creating a fabricated scenario (pretext) to obtain information from a target. The attacker might impersonate a trusted figure, such as a colleague, IT administrator, or vendor, to request sensitive information.
    - For example, an attacker could call an employee, pretending to be an IT support technician, and ask for login credentials or other sensitive data under the guise of helping with a technical issue.
4. **Dumpster Diving**:
    - This involves physically going through a company's trash or discarded items to find useful information. For example, an attacker may recover old documents, post-it notes with passwords, outdated employee records, or sensitive corporate data that wasn't properly shredded or disposed of.
    - While not strictly digital, dumpster diving is still part of the reconnaissance phase, as attackers attempt to find sensitive information that can be used to facilitate further attacks.
5. **Shoulder Surfing**:
    - **Shoulder surfing** is when an attacker observes an individual in person (often in a public or semi-public place, like a coffee shop or office) to gather sensitive information like login credentials, PINs, or private conversations.
    - This form of social engineering reconnaissance typically occurs in places where an individual may be entering passwords or engaging in other sensitive activities.
6. **Baiting**:
    - In baiting, attackers offer something enticing to lure victims into a trap. This could involve leaving infected USB drives in public places (hoping someone will plug it into their computer) or offering free downloads that contain malware. The reconnaissance phase helps attackers identify individuals or groups likely to take the bait.
7. **Phone-Based Social Engineering**:
    - **Vishing** (voice phishing) involves using the phone to manipulate individuals into providing personal information. The attacker could impersonate a trusted authority figure or use a sense of urgency (e.g., claiming an account is at risk) to get the victim to reveal sensitive information.
    - During reconnaissance, attackers might research the organization's key phone numbers, and employee contact details, or even find out which numbers to spoof for credibility.
8. **Building Trust (Impersonation)**:
    - Social engineers may also use techniques to build trust with targets over time. This might involve establishing rapport or finding common ground. By doing so, the attacker becomes more believable and the target is more likely to divulge sensitive information.
    - For instance, an attacker might impersonate a vendor or an employee and build a relationship with a target to extract sensitive details later.

### Goals of Social Engineering Reconnaissance:

The primary goal of social engineering reconnaissance is to gather information that can be used to manipulate individuals into compromising security measures. Specific objectives include:

- **Identifying vulnerable individuals**: Finding people who are more likely to fall for scams or who have access to sensitive information.
- **Building a profile of the target**: Collecting personal details (e.g., birthdays, family members, interests) to make interactions seem more legitimate and personal.
- **Accessing sensitive systems or locations**: Gaining credentials, physical access to restricted areas, or confidential information through trust-building or deception.
- **Finding weaknesses in security policies**: Spotting weak spots in an organization's security policies, such as an over-reliance on a single form of authentication or lack of staff training on security awareness.

### Tools and Resources Used in Social Engineering Reconnaissance:

- **Social Media Platforms**: LinkedIn, Facebook, Instagram, Twitter, Reddit, etc.
- **Google Dorking**: Using advanced search operators to find hidden information that might not be directly accessible on a website.
- **People Search Engines**: Websites like Spokeo, Pipl, and BeenVerified to gather information on individuals.
- **Public Databases**: WHOIS records, company filings, employee directories, and public registries.
- **Email Harvesting Tools**: Tools to collect and target email addresses for phishing campaigns.
- **Phone Lookup Tools**: Services like TrueCaller to identify and track phone numbers.

### Mitigation and Defense:

Organizations can take steps to protect against social engineering attacks by reducing their susceptibility during the reconnaissance phase:

- **Employee Awareness Training**: Educate employees about social engineering tactics and the importance of verifying suspicious requests.
- **Limit Information Sharing**: Be mindful of what is shared online and what personal or sensitive details are accessible through public records or social media.
- **Verify Requests**: Encourage employees to verify unsolicited requests for sensitive information via independent channels (e.g., phone calls, official emails).
- **Implement Strong Authentication**: Use multi-factor authentication (MFA) to reduce the risk of unauthorized access.
- **Protect Physical Information**: Ensure that physical documents are shredded, and discarded materials are securely disposed of.

## 3.8 Scanning

**Scanning in reconnaissance** refers to the process of actively probing a network, system, or device to gather detailed information about it. It's a critical phase in cybersecurity assessments, especially during penetration testing, where security professionals (or attackers) try to identify vulnerabilities, open ports, services, and configurations that could be exploited. Scanning provides a deeper level of detail than passive reconnaissance and can help uncover weaknesses that were not immediately visible through simpler techniques.

There are several types of scanning

1. Network Scanning

2. Port Scanning
3. Service Version Scanning
4. Operating System (OS) Fingerprinting
5. Vulnerability Scanning
6. Banner Grabbing
7. Web Application Scanning
8. IP Scanning
9. DNS Scanning
10. SMB Scanning
11. Ping Sweep
12. HTTP Header Scanning
13. SMTP Scanning
14. FTP Scanning
15. Telnet Scanning
16. Wi-Fi Scanning
17. Database Scanning

3.9 Port scanning

A port scan is a common technique hackers use to discover open doors or weak points in a network. A port scan attack helps cyber criminals find open ports and figure out whether they are receiving or sending data. It can also reveal whether active security devices like firewalls are being used by an organization.

When hackers send a message to a port, the response they receive determines whether the port is being used and if there are any potential weaknesses that could be exploited.

Businesses can also use the port scanning technique to send packets to specific ports and analyze responses for any potential vulnerability. They can then use tools like IP scanning, network mapper (Nmap), and Netcat to ensure their network and systems are secure.

Port scanning can provide information such as:

1. Services that are running
2. Users who own services
3. Whether anonymous logins are allowed
4. Which network services require authentication

**What is a Port?**

A port is a point on a computer where information exchange between multiple programs and the internet to devices or other computers takes place. To ensure consistency and simplify programming processes, ports are assigned port numbers. This, in conjunction with an IP address, forms vital information that each internet service provider (ISP) uses to fulfill requests.

Port numbers range from 0 through to 65,536 and are ranked in terms of popularity. Ports numbered 0 to 1,023 are called “well-known" ports, which are typically reserved for internet usage but can also have specialized purposes. These ports, which are assigned by the Internet Assigned Numbers Authority (IANA), are held by leading businesses and Structured Query Language (SQL) services.

Ports are generally managed by the Transmission Control Protocol (TCP), which defines how to establish and maintain a network conversation between applications, and User Datagram Protocol (UDP), which is primarily used for establishing low-latency and loss-tolerating connections between applications. Some of the most popular and most frequently used ports include:

1. Port 20 (UDP): File Transfer Protocol (FTP) used for transferring data
2. Port 22 (TCP): Secure Shell (SSH) protocol used for FTP, port forwarding, and secure logins
3. Port 23 (TCP): The Telnet protocol used for unencrypted communication
4. Port 53 (UDP): The Domain Name System (DNS), which translates internet domain names into machine-readable IP addresses
5. Port 80 (TCP): The World Wide Web Hypertext Transfer Protocol (HTTP)

Ports numbered from 1,024 to 49,151 are considered "registered ports," and they are registered by software companies. The ports numbered from 49,152 to 65,536 are considered dynamic and private ports, which can be used by almost everyone on the internet.

**What are the Port Scanning Techniques?**

A port scan sees packets sent to destination port numbers using various techniques. Several of these include:

1. Ping scans: A ping scan is considered the simplest port scanning technique. They are also known as internet control message protocol (ICMP) requests. Ping scans send a group of several ICMP requests to various servers in an attempt to get a response. A ping scan can be used by an administrator to troubleshoot issues, and pings can be blocked and disabled by a firewall.
2. Vanilla scan: Another basic port scanning technique, a vanilla scan attempts to connect to all of the 65,536 ports at the same time. It sends a synchronize (SYN) flag, or a connect request. When it receives a SYN-ACK response, or an acknowledgment of connection, it responds with an ACK flag. This scan is accurate but easily detectable because a full connection is always logged by firewalls.
3. SYN scan: Also called a half-open scan, this sends a SYN flag to the target and waits for a SYN-ACK response. In the event of a response, the scanner does not respond back, which means the TCP connection was not completed. Therefore, the interaction is not logged, but the sender learns if the port is open. This is a quick technique that hackers use to find weaknesses.
4. XMAS and FIN scans: Christmas tree scans (XMAS scans) and FIN scans are more discrete attack methods. XMAS scans take their name from the set of flags that are turned on within a packet which, when viewed in a protocol analyzer like Wireshark, appear to be blinking like a Christmas tree. This type of scan sends a set of flags, which, when responded to, can disclose insights about the firewall and the state of the ports. A FIN scan sees an attacker send a FIN flag, often used to end an established session, to a specific port. The system's response to it can help the attacker understand the level of activity and provide insight into the organization's firewall usage.
5. FTP bounce scan: This technique enables the sender to disguise their location by using an FTP server to bounce a packet.
6. Sweep scan: This preliminary port scanning technique sends traffic to a port across several computers on a network to identify those that are active. It does not share any information about port activity but informs the sender whether any systems are in use.

**Different Types of Port Checker or Scanner**

There are several different port scanning or checking techniques, including:

1. **Ping scans:** A ping is used to check whether a network data packet can reach an IP address without any issues. Ping scans involve automated transmissions of several ICMP requests to various servers.
2. **Half-open or SYNC scans:** Attackers can check the state of a port without creating a full connection by using a half-open scan, often known as a SYN scan. This kind of scan just transmits a SYN message and does not complete a connection with the recipient.
3. **XMAS scans:** XMAS scans send a number of packets to a port to check if it is open. If the port is closed, the scanner gets a response. If it does not get a response, that means the port is open and can be used to access the network.

**What type of port scan results can you get from port scanning?**

Port scan results reveal the status of the network or server and can be described in one of three categories: open, closed, or filtered.

- **Open ports:** Open ports indicate that the target server or network is actively accepting connections or datagrams and has responded with a packet that indicates it is listening. It also indicates that the service used for the scan (typically TCP or UDP) is in use as well.
  Finding open ports is typically the overall goal of port scanning and a victory for a cybercriminal looking for an attack avenue. The challenge for IT administrators is trying to barricade open ports by installing firewalls to protect them without limiting access for legitimate users.
- **Closed ports:** Closed ports indicate that the server or network received the request, but there is no service "listening" on that port. A closed port is still accessible and can be useful in showing that a host is on an IP address. IT administrators should still monitor closed ports as they could change to an open status and potentially create vulnerabilities. IT administrators should consider blocking closed ports with a firewall, where they would then become "filtered" ports.
- **Filtered ports:** Filtered ports indicate that a request packet was sent, but the host did not respond and is not listening. This usually means that a request packet was filtered out and/or blocked by a firewall. If packets do not reach their target location, attackers cannot find out more information. Filtered ports often respond with error messages reading "destination unreachable" or "communication prohibited."

**3.10 Network Scanning**

Network scanning is the process of troubleshooting the active devices on your system for vulnerabilities. It identifies and examines the connected devices by deploying one or more features in the network protocol. These features pick up vulnerability signals and give you feedback on the security status of your network.

Network scanning facilitates system maintenance, monitoring, and security assessments. When implemented effectively, network scanning gives you insights into some of the best ways to protect your network against cyberattacks.

**How Does Network Scanning Work?**

Network scanning is simplified with innovative solutions. One way to implement network scanning without breaking your back is the use of network administrators.

Network administrators scan your network to evaluate IP addresses and detect live hosts connected to it.

Keep in mind that cybercriminals use the same technique to spot weaknesses in your network. The idea is to identify the loopholes before the bad guys discover them.

For network administrators to identify how IP addresses are mapped in the network, they may need to use tools such as Nmap.

Nmap is an effective network scanning tool that uses IP packets to detect devices attached to a network. It helps to simplify the mapping of IP addresses.

You can use network scanners to inspect where the network is stronger or weaker in your workplace with the help of network administrators.

A basic working rule of network scanning is to identify all devices on a network and map their IP addresses. To do this, you must use the network scanner to forward a packet to all available IP addresses connected to the network.

After sending this ping, you need to wait for their response. Once the feedback arrives, the network scanner uses them to measure the status and inconsistencies of the host or application. During this process, the responding devices are active while the non-responding devices are inactive.

Network administrators can also use Address Resolution Protocol (ARP) scan to evaluate the system manually. But if the goal of the network administrator is to reach all active hosts, it's advisable to use tools that support automatic running scans.

One of the best tools that you can use to attain such a milestone is the Internet Control Message Protocol (ICMP) scan. It helps you map the network accurately without failure.

Many security-conscious companies allocate high budgets to advanced network scanning tools to secure their networking systems. But they may not get the desired results if they make the wrong choice. The effective scanning tools you should consider include, Acunetix, Nikto, Spyse, Swascan, IP Address Manager, and SolarWinds Network Performance Monitor.

**Types of Network Scanners**

Scanning your network properly requires using the right tools and methods. Each method is determined by what you want to achieve with your scanning. There are two major kinds of network scanning—port scanning and vulnerability scanning.

**1. Port Scanning**

Port scanning enables you to identify open ports in a network that can receive or send data. You can use it to send packets to targeted ports on a device. This process highlights loopholes and analyzes performance feedback.

Before implementing port scanning, you have to identify the list of active devices and maps to their IP addresses.

The primary goal of port scanning is to use the data it acquires from active devices to diagnose security levels.

**2. Vulnerability Scanning**

Vulnerability scanning helps you to detect vulnerabilities that exist on your network. Running a check on your system exposes threats that were hidden away from you.

In most organizations, vulnerability scanning is conducted by the IT department. But if you want to get thorough feedback, consider hiring a third-party security expert. Since they aren't familiar with your network, they'll conduct an objective analysis from an outsider's perspective.

Vulnerability scanning can also be performed by cyberattackers intending to identify weak spots in your network. Beat them to it by identifying and closing the weak links.

Besides identifying loopholes, vulnerability scanning also evaluates the security capacity of your network against cyberattacks. It uses a database to analyze possible attacks. This database provides the vulnerability scanner with packet construction anomalies, flaws, default configurations, paths to sensitive data, and coding bugs that can enable cyber attackers to exploit your network.

**What Are the Benefits of Network Scanning?**

Like most innovative solutions, network scanning offers several benefits. One thing is certain—it gives your system a better footing. In what ways exactly, though? Let's take a look.

**1. Increased Network Performance**

Network scanning plays a key role in increasing network performance and maximizing the speed of network operations.

In a complex organizational network, multiple subnets of various IP addresses are assigned to several devices to improve their performance on the system. Scanning these devices helps to remove clogs and creates a free flow for optimal performance.

**2. Protection Against Cyberattacks**

Network scanning is so useful that cybercriminals also use it to discover vulnerabilities in a network. When you fail to scan your network for threats and vulnerabilities, you're indirectly inviting attackers for a visit.

Carrying out regular network scanning is an effective way to keep your system free from cyberattacks. It's similar to implementing intrusion detection systems to spot emerging threats.

**3. Save Time and Money**

Scanning your network manually is tedious and time-consuming. The scanning process could linger for long. Your work is on hold, making you lose money in the long run.

Network scanning is an automated process. It evaluates tons of data within a short time. You get it over with as soon as possible and keep your workflow moving.

The purpose of network scanning is as follows:

- Recognize available UDP and TCP network services running on the targeted hosts
- Recognize filtering systems between the user and the targeted hosts
- Determine the operating systems (OSs) in use by assessing IP responses
- Evaluate the target host's TCP sequence number predictability to determine sequence prediction attack and TCP spoofing

### 3.10 Vulnerability Scanning

Vulnerability scanning is the process of discovering, analyzing, and reporting on security flaws and vulnerabilities. Vulnerability scans are conducted via automated vulnerability scanning tools to identify potential risk exposures and attack vectors across an organization's networks, hardware, software, and systems. Vulnerability scanning and assessment is an essential step in the vulnerability management lifecycle.

Once vulnerabilities have been identified through scanning and assessed, an organization can pursue a remediation path, such as patching vulnerabilities, closing risky ports, fixing misconfigurations, and even changing default passwords, such as on internet of things (IoT) and other devices.

#### The Benefits of Vulnerability Scanning

Vulnerability scanning is a vital part of your security team's overall IT risk management approach for several reasons

- Vulnerability scanning lets you take a proactive approach to close any gaps and maintain strong security for your systems, data, employees, and customers. Data breaches are often the result of unpatched vulnerabilities, so identifying and eliminating these security gaps, removes that attack vector.
- Cybersecurity compliance and regulations demand secure systems. For instance, NIST, PCI DSS, and HIPAA all emphasize vulnerability scanning to protect sensitive data.
- Cyber criminals also have access to vulnerability scanning tools, so it is vital to carry out scans and take restorative actions before hackers can exploit any security vulnerabilities.

#### The Main Types of Vulnerability Scans

Some of vulnerability scanning tools are comprehensive in their coverage, able to perform multiple types of scans across heterogeneous environments that include on-prem, Unix, Linux, Windows, cloud, off-site, and onsite. Other scanning tools serve particular niches, so it's always critical to thoroughly explore your use cases before investing in a scanner.

Let's now explore some different types of vulnerability scans, which each have their place, depending on your use cases.

#### Credentialed Scans vs. Non-Credentialed Scans

Credentialed and non-Credentialed scans (also respectively referred to as authenticated and non-authenticated scans) are the two main categories of vulnerability scanning.

Non-credentialed scans, as the name suggests, do not require credentials and do not get trusted access to the systems they are scanning. While they provide an outsider's eye view of an environment, they tend to miss most vulnerabilities within a target environment. So, while they can provide some valuable

insights to a potential attacker as well as to a security professional trying to gauge risk from the outside, non-credentialed scans give a very incomplete picture of vulnerability exposure.

On the other hand, credentialed scans require logging in with a given set of credentials. These authenticated scans are conducted with a trusted user's eye view of the environment. Credentialed scans uncover many vulnerabilities that traditional (non-credentialed) scans might overlook. Because credentialed scans require privileged credentials to gain access for scanning, organizations should look to integrate an automated privileged password management tool with the vulnerability scanning tool, to ensure this process is streamlined and secure (such as by ensuring scan credentials do not grow stale).

Here are some other ways that scans may be categorized, based on use case.

**External Vulnerability Scans**

These scans target the areas of your IT ecosystem that are exposed to the internet, or are otherwise not restricted to your internal users or systems. They can include websites, ports, services, networks, systems, and applications that need to be accessed by external users or customers.

**Internal Vulnerability Scans**

These scan and target your internal corporate network. They can identify vulnerabilities that leave you susceptible to damage once a cyberattacker or piece of malware makes it to the inside. These scans allow you to harden and protect applications and systems that are not typically exposed by external scans.

**Environmental Scans**

These scans are based on the environment that your technology operates in. Specialized scans are available for multiple different technology deployments, including cloud-based, IoT devices, mobile devices, websites, and more.

**Intrusive Versus Non-Intrusive Scans**

Non-intrusive scans simply identify a vulnerability and report on it so you can fix it. Intrusive scans attempt to exploit a vulnerability when it is found. This can highlight the likely risk and impact of a vulnerability, but may also disrupt your operational systems and processes, and cause issues for your employees and customers — so use intrusive scanning with caution.

**Vulnerability Scanning Challenges**

There are several challenges that arise in conducting vulnerability scanning:

**A scan only represents a moment in time**

Most scans are "snapshots," not continuous. Because your systems are changing all the time, you should run scans regularly as your IT ecosystem changes

**A scan may need human input or further integrations to deliver value**

Although the scanning process itself is easily automated, a security expert may still need to review the results, complete remediation, and follow-up to ensure risks are mitigated. Many organizations also integrate vulnerability scanning with automated patch management and other solutions to help reduce the human administrative burden. Regardless, the scan itself is only an early step in the vulnerability management lifecycle.

**A credentialed scan may require many privileged access credentials**

Depending on how thorough a scan is desired. Therefore automating management and integration of these credentials with scanner should be considered to maximize both the depth of the scan, and privileged access security.

**A scan only identifies known vulnerabilities**

A vulnerability scanning tool is only as good as its database of known faults and signatures. New vulnerabilities emerge all the time, so your tool will need to be continually updated.

### 3.11 Scanning methodology

**Scanning methodology** refers to a systematic approach used during the scanning phase of cybersecurity reconnaissance. This methodology helps to identify open ports, active services, potential vulnerabilities, and weak spots in a network or system. The process is often part of penetration testing or vulnerability assessments and follows a structured approach to ensure comprehensive coverage and minimize risk.

Common Steps in a Scanning Methodology:

1. **Preparation and Information Gathering (Reconnaissance)**
   - **Passive Reconnaissance**: Gathering information about the target without interacting directly with it (e.g., WHOIS lookups, social media searches, and domain analysis).
   - **Active Reconnaissance**: Interacting with the target system to gather detailed data through scanning techniques. This phase involves the use of tools to identify live hosts, open ports, and services.
2. **Network Scanning**
   - **Objective**: Identify live hosts on the target network.
   - **Method**: Use ping sweeps or ARP scans to determine which devices are active on the network.
   - **Tools**: Nmap, Angry IP Scanner, Fping.
3. **Port Scanning**
   - **Objective**: Detect open ports and the services running on them.
   - **Method**: Scan for both common and uncommon ports (e.g., 80 for HTTP, 443 for HTTPS, 21 for FTP).
   - **Tools**: Nmap, Masscan, Hping.
   - **Techniques**:
     - **TCP Connect Scan**
     - **SYN Scan (Half-Open Scan)**
     - **UDP Scan**
4. **Service Version Scanning**
   - **Objective**: Identify the version of the services running on open ports.
   - **Method**: After discovering open ports, check the service version to determine potential vulnerabilities.
   - **Tools**: Nmap (`-sV`), Nessus.
   - **Purpose**: Helps determine the software or service version to check against known vulnerabilities.
5. **Operating System (OS) Fingerprinting**
   - **Objective**: Identify the operating system running on the target system.
   - **Method**: Analyze network responses (e.g., TTL values, TCP/IP stack behavior) to deduce the OS.
   - **Tools**: Nmap, XProbe, p0f.
6. **Vulnerability Scanning**
   - **Objective**: Scan for known vulnerabilities in services, applications, and configurations.
   - **Method**: Compare the system configurations and service versions with a database of known vulnerabilities.
   - **Tools**: Nessus, OpenVAS, Qualys, Nexpose.
   - **Purpose**: Identifies potential vulnerabilities that could be exploited.
7. **Banner Grabbing**
   - **Objective**: Gather details about a service running on an open port by capturing its banner (information about the software version, service type, etc.).
   - **Method**: Connect to open ports (e.g., HTTP, FTP) and retrieve the banner information.
   - **Tools**: Netcat, Nmap, Telnet.

8. **Web Application Scanning**
    - **Objective**: Identify vulnerabilities specific to web applications (e.g., SQL injection, XSS).
    - **Method**: Scan web applications for weaknesses like poor input validation and misconfigured settings.
    - **Tools**: Burp Suite, OWASP ZAP, Nikto.
9. **Post-Scanning Enumeration**
    - **Objective**: Collect more detailed information about discovered services, users, and configuration settings.
    - **Method**: Enumerate open services like SMB, FTP, and DNS to gather usernames, shares, and other details.
    - **Tools**: Enum4linux (for SMB), Netcat, Metasploit.
10. **Reporting and Analysis**
    - **Objective**: Summarize the findings, identify critical vulnerabilities, and offer mitigation strategies.
    - **Method**: Compile the data from scanning tools, analyze the results, and document vulnerabilities.
    - **Tools**: Various analysis tools depending on the scan type.
    - **Purpose**: Help the organization understand risks and improve their security posture.

**Steps for scanning methodologies**

**1.** Check for live systems. Something as simple as a ping can provide this. This gives you a list of what's actually alive on your network subnet.

**2.** Check for open ports. Once you know which IP addresses are active, find what ports they're listening on.

**3.** Scan beyond IDS. Sometimes your scanning efforts need to be altered to avoid those pesky intrusion detection systems.

**4.** Perform banner grabbing. Banner grabbing and OS fingerprinting will tell you what operating system is on the machines and which services they are running.

**5.** Scan for vulnerabilities. Perform a more focused look at the vulnerabilities these machines haven't been patched for yet.

**6.** Draw network diagrams. A good network diagram will display all the logical and physical pathways to targets you might like.

**7.** Prepare proxies. This obscures your efforts to keep you hidden. Scanning Methodology

- **Check for Live Systems:** Ping scan checks for the live system by sending ICMP echo request packets. If a system is alive, the system responds with ICMP echo reply packet containing details of TTL, packet size etc.

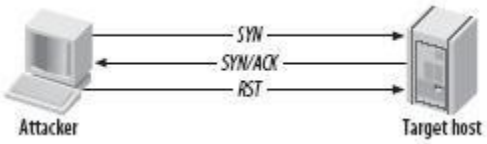
- **Check for Open Ports:** Port scanning helps us to find out open ports, services running on them, their versions etc. Nmap is the powerful tool used mainly for this purpose.

**We have various types of scan:**

**Connect scan:** Identifies open ports by establishing a TCP handshake with the target.

Nmap command: nmap -sT -v -p- <TargetIP>

**Half-open scan** otherwise known as Stealth scan used to scan the target in a stealthy way by not completing the TCP handshake by abruptly resetting the communication.




Source: https://www.safaribooksonline.com

Nmap command: nmap -sS -v <TargetIp>

**XMAS scan:** This is also called as inverse TCP scanning. This works by sending packets set with PSH, URG, FIN flags. The targets do not respond if the ports are open and send a reset response if ports are closed.

Source: https://www.information-security.fr

**FIN scan:** Fin flag is set in the TCP packets sent to the target. open ports doe does not respond while closed ports send a reset response.

Source: https://securitcrs.wordpress.com

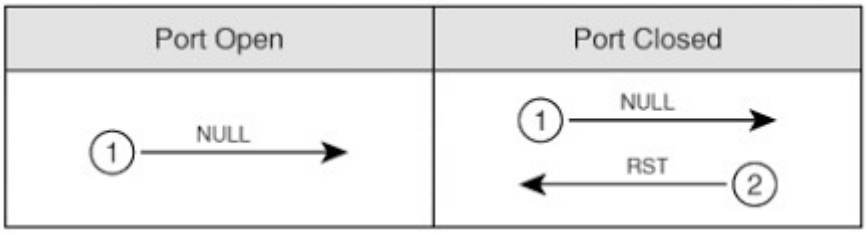
Nmap command: nmap -SF <targetIp>

**ACK scan:** Here the attacker sets the ACK flag in the TCP header and the target's port status is gathered based on window size and TTL value of RESET packets received from the target.

Source: https://www.hackingloops.com

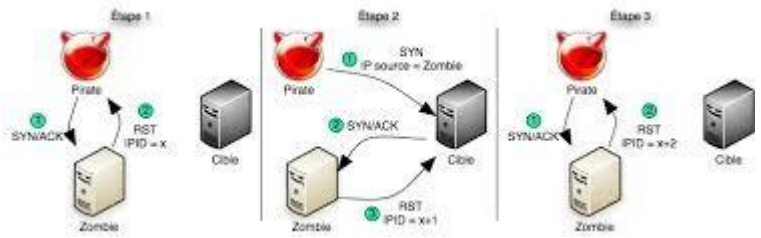
Nmap command: nmap -SA -v <targetip>

**Null Scan:** Works by sending TCP packets with no flags set to the target. Open ports do not respond while closed ports respond with a RESET packet.




Nmap Command: nmap -sN -p- <targetIP>

**Idle Scan:** Here the attacker tries to mask his identity uses an idle machine on the network to probe the status details of target ports.




Source: https://en.wikipedia.org/wiki/Idle_scan

Nmap command : nmap -Pn -sI ZombieIp TargetIp

**Banner Grabbing**

Banner grabbing is a process of collecting information like operating system details, the name of the service running with its version number etc.

**Vulnerability scanning:**

Mainly automated tools are used for this purpose. These automated scanners scan the target to find out vulnerabilities or weakness in the target organization which can be exploited by the attackers.

Vulnerabilities include application vulnerabilities, configuration vulnerabilities, network vulnerabilities, operating system vulnerabilities etc.

Some examples include operating system is not updated, default passwords used, plain text protocols used, vulnerable protocols running etc.

Tools: Nessus, Acunetix

**Draw Network Diagrams**

With the information gathered, the attacker can come up with a network diagram which might give him information about network and architecture of the target organization helping him to identify the target easily

Tools: Network View, Opmanager etc

**Prepare Proxies**

Proxies can use to maintain the anonymity of the attacker by masking the IP address. It can capture information passing through it since it acts as an intermediary between client and server and the attacker can access the resources remotely using the proxies.

Eg: TOR browsers, Onion sites etc, Proxify, Psiphon etc

**Countermeasures:**

- Configure IDS and firewall to block probes.
- Keep firewall, routers, IDS firmware update
- Run port scanners to verify the security of the target.
- Add rules in firewall restricting access to ports.
- Disable ICMP based scanning at firewall.

**3.12 Ping Sweep**

The IP address has many functionalities. Ping sweep is a term related to it. Scanning ping is one of the most efficient ways to find network vulnerabilities and tackle network-related discoveries. It also saves lots of time because the procedure related to ping sweep is pretty simple. Pinging a simple service similar to google.com gives back many results and we can learn our situation depending on the result we get back.Pinging a network or system allows us to determine if a host is alive or dead.
This network-based utility can ping one simple IP or brute check a list of IPs in a single or continuous scan. In response to pinging a host, we get back data as an echo. By calling it alive, we can identify if the system is active and what is the network-based status around it. And dead means the host is either inactive or non-responsive or in shutdown mode. Hosts can be the network servers, computers, websites, printers, or any remote network device.

Ping Sweep is an information-gathering technique used to identify live hosts by pinging them. In more technical terms it is also known as Ping scan, or Internet Control Message Protocol (ICMP). One host like the user requests data and the receiver host accepts it, furthermore sends back packets of information in bytes. In between these packets they get validated and a response comes back to the sender host. For this reason, ping sweep or ping scan is also known as a two-way handshake protocol.

**Ping and Ping Sweep are not the same**

The use of ping system first began with sonar technology. There are numerous numbers of submarines

that go deep into the ocean and visibility is zero there. No light can pass, but the sound waves can. As water is a great conductor of sound. What sonar technology does is, sends signals in all directions.
The sonar signal bounces back from obstacles on all sides, making it possible to map live data from around the area. The system was called pinging and thus we got the name, but in computing, it is used as an IP network utility tool and called pinging.

Network administrators have the capability to ping devices connected to a specific network. Of course, that has to be on a network. On the other hand, as we've talked about ICMP, ping sweep, we can help diagnose a network issue quickly and find what's going on with the host. Even remote devices on different IPs can be accessed by sweeping ping.

**Purpose of Ping Sweep**

Ping sweep is used to gain various information over the host. It has the potential to address a range of IPs for live mapping. In regular pinging, we have echo request and echo-response functions. It's a way of data request and gaining sufficient knowledge on a network device. It can also map a range of IPs. Echo request reveals information regarding the IP we ping. Local pinging directs via local DNS server and input has a round-trip time (RTT). But ping sweep uses ICMP echo request. It can send packets of data to reveal in-depth information about a host or range of hosts. Finding out live and dead Ips, detecting bad traffic and rogue network devices, and matching only permitted IPs on the network are a few results that can be documented by ping sweeping. Regular pinging can be done on console command on admin devices but ICMP echoing requires advanced software packages. Same reason they can be manipulated any way the admin wants to achieve live mapping a DHCP environment.

Generally, we can either conduct a Normal Ping Sweep or Flood Pinging. Once we have the target IP address of the host, we can ping that IP address and determine whether the host is alive or not. Once packets are received correctly, then we can confirm host stats. The data will help in conducting further work on the host. This is a normal ping sweep.

On the other hand, flood pinging is quite like a denial-of-service attack. It occurs when a website or host is flooded with lots of pings. The result of it is pretty serious. Regular legitimate users may not use the service or host at the time of flood pinging moment. Every website or victim network has a maximum capacity and when flood pinging crosses that limit, it jams the network and the host stops responding. Automated scripts or flood pinging software are used for this kind of experiment. Flood pinging is sometimes called a "Ping of Death" as it makes the host behave like a dead host. Flood pinging is mostly used for session hijacking.

**Best tools for Ping Sweep**

Since there are many tools to map Ping Sweep, we are only highlighting the best ones. They are simple to use and can perform all the advanced tasks easily that an admin may require. As ping sweep requires packages and special features, it is important to use tools. It saves time and the display systems in tolls are well thought out. Reveling and going through data becomes easier for anyone looking to find a situation of network or finding vulnerabilities. Our top pick consists of:

1. SolarWinds IP Address Manager (IPAM)
2. SolarWinds Engineer's Toolset (ETS)
3. ManageEngine OpManager
4. Advanced IP Scanner
5. Paessler PRTG Network Monitor

3.13 Nmap command switches

Nmap is probably the most famous reconnaissance tool among Pentesters and Hacker. It is essentially a port scanner that helps you scan networks and identify various ports and services available in the network, besides also providing further information on targets, including reverse DNS names, operating system guesses, device types, and MAC addresses. It also comes in handy during network auditing!

**The barebone syntax of Nmap is:**

```
$ nmap [FLAGS] [IP]
```

Copy

Note that you may also need to run it with **sudo** privileges at times to perform some particular types of scans,

**Nmap Switches**

Nmap is strong and powerful networking scanning to tool which allows for customizing our scans with the help of flags passed via the command line. Some of the important flags are :

- -h: Print a help summary page
- -sS: Perform a TCP SYN scan
- -sU: Perform a UDP scan
- -sV: Probe open ports to determine service/version info
- -O: Enable OS detection
- -v: Enable verbosity. You can even set the verbosity level as such :
    - -vv: Level 2 verbosity. The minimum level of verbosity advised for use.
    - -v3: Level 3 verbosity. You can always specify the verbosity level by specifying a number like this.
- -oA: Same Nmap output in “normal”, XML and grepable formats. However you can specify the format of your choice with :
    - -oN: Redirect normal output to a given filename
    - -oX: Produce output in a clean, XML format and store it in a given file
    - -oG: Produce “grepable” output and store it to a file. Deprecated format as users are now moving towards XML outputs.
- -A: Enables “aggressive” scanning. Presently this enables OS detection (-O), version scanning (-sV), script scanning (-sC) and traceroute (–traceroute)
- -p: Specify the ports to scan. It can be a single port as well as a range of ports. For Example :
    - nmap -p 80 127.0.0.0.1: This scans port 80 on localhost
    - nmap -p 1-100 127.0.0.1: This scans ports from 1 to 100 on localhost
    - nmap -p- 127.0.0.1: This scans all the ports on the localhost

**Scan Types in Nmap**

Nmap supports a lot of different scan types. However the most popular ones are:

**1. TCP Connect Scans (-sT)**

In this type of scan, Nmap sends a TCP packet to a port with the SYN flag set. In this scenario two things can occur :

- The target responds with an RST packet that signifies that the port is closed.
- Target doesn't respond at all, probably due to a firewall dropping all incoming packets in which case the port will be considered filtered
- The target responds back with a TCP packet with the SYN/ACK flags set which would signify that the port is open and then Nmap would respond with a TCP packet with the ACK flag set and hence would complete the TCP 3-way handshake.

This is not a very reliable scan technique as it is easy to configure a firewall rule to respond back with RST packets or drop all incoming packets. Also this method is extremely slow as it waits for the entire TCP 3 way handshake.

**2. SYN "Half-open" Scans (-sS)**

SYN scans, also known as "Half-Open" or "Stealth Scan" are an improvement over the previous method. In the previous method where we were sending back a TCP packet with the ACK flag set after receiving an SYN/ACK packet, now we would be sending an RST packet. This prevents the server from repeatedly trying to make the requests and massively reduces scan times.

This method is an improvement on the previous ones because:

- They are faster
- They might be able to bypass some primitive firewalls
- Often, SYN Scans are not logged by applications running on the ports as most applications start logging a connection only after it has been fully established which is not the case with SYN Scans

However, it is not advisable to run SYN Scans on production environments as it might break certain unstable applications. It is also to be noted that SYN scans also require sudo privileges because it needs to craft raw packets.

Infact, when run with sudo privileges, nmap defaults to SYN Scans, otherwise it defaults to TCP scan.

**3. UDP Scans (-sU)**

UDP scans are much less reliable than the previous two as UDP connections are stateless by nature. This means that there's no "feedback mechanism" like TCP. UDP works on the principle "Fire and Forget" which means that it sends packets directed to targets at certain ports and hopes that they would make it. This gives more emphasis on speed than quality. However, the lack of a feedback mechanism makes it difficult to identify open ports.

When an UDP packet is sent to a target port, there might be three scenarios :

- Usually there is no response received in which case nmap marks the port as open|filtered. If no response is received yet, it sends another UDP packet to double check and if yet again no response is received, it marks the port as open|filtered and moves on
- It might get a UDP response back which is very rare. In such a scenario, the port is marked open

- If the port is closed and it receives an ICMP echo request back which signifies that the port is unreachable.

**Special Scans in Nmap**

Apart from these, some less popular scan types which are even “stealthier” than a TCP SYN scan. These are as follows :

**1. TCP Null Scans (-sN)**

In TCP Null Scans, the TCP packets sent don’t have any of the flags set. According to RFC, under such a circumstance, the target should respond back with an RST if the port i s closed

**2. TCP FIN Scans (-sF)**

This is very similar to the TCP Null Scan except for the fact that instead of sending a completely empty TCP packet, it sends a packet with the FIN flag set which is used to gracefully close a connection. Accordingly the target must respond back with an RST for closed ports as per RFC.

**3. TCP Xmas Scans (-sX)**

TCP Xmas Scans is also very similar to the last two scan techniques except for the fact that they use TCP packets with the PSH, URG and FIN flags set. Like the last two scan types, this too expects RST packets for closed ports under RFC.

**Limitations**

As these scans are of a similar nature, they also have similar outputs which is very similar to that of UDP Scans. In this case, we can only have the following three responses :

- open|filtered : When no response is received then the port is categorized as this this because no response can mean only two things :
    - The port is open
    - The port is protected behind a firewall hence filtered
- filtered : When the port is protected behind a firewall which sends an ICMP ping back
- closed : When it receives and RST packet

It is also to be note that though RFC 793 mandates that network hosts respond to malformed packets with a RST TCP packet for closed ports, and don’t respond at all for open ports, some systems reject this convention. This behaviour is mostly observed in Microsoft Windows Servers and some CISCO devices where all malformed packets are dropped by default.

**Scanning A Network For Hosts using Nmap**

One of the most important things to do on connecting to a network is to obtain a list of all active hosts on the network before further probing. This can be done via an “Ping Sweep”, which as the name implies, involves sending ICMP packet to all the IPs in the network and await for responses. The hosts which reply back with an ICMP packet are considered active in this case.

You can specify your target IP ranges by using hypens or via CIDR as follows :

```
$ nmap -sn 192.168.0.1-254
```

Copy

Or,

$ nmap -sn 192.168.0.0/24

Copy

The -sn flag suppresses any port scans, and forces nmap to rely solely on ICMP echo packets (or ARP requests if run with superuser privileges) to identify active hosts in the network. It also sens a TCP SYN packet to the target's port 443 and a TCP ACK request ( TCP SYN if run with superuser privileges) to the target's port 80.

**Nmap Scripting Engine**

The Nmap Scripting Engine(NSE) is a powerful addition to Nmap which allows us to even further extend its functionality. Written in Lua, we can use it to write our scripts and automate a lot of our work like testing for vulnerabilities and exploitation.

There are many categories available. Some useful categories include:

- safe:- Won't affect the target
- intrusive:- Not safe: likely to affect the target
- vuln:- Scan for vulnerabilities
- exploit:- Try to exploit a vulnerability
- auth:- Attempt to bypass authentication for running services
- brute:- Try to brute force credentials for running services
- discovery:- Attempt to query running services for further information about the network (

To run a script, we need to specify it as --script=<script-name>

You can also specify multiple scripts to run at the same time by separating the script names like --script=<script-name1>,<script-name2>

Some scripts also require an argument which can be specified with --script-args <args>

Some scripts have an built-in help menus which can be referred with :

$ nmap --script-help <script-name>

**3.14 SYN**

A SYN or stealth scan is also called a half-open scan because it doesn't complete the TCP three-way handshake. A hacker sends a SYN packet to the target; if a SYN/ACK frame is received back, then it's assumed the target would complete the connect and the port is listening. If an RST is received back from the target, then it's assumed the port isn't active or is closed. The advantage of the SYN stealth scan is that fewer IDS systems log this as an attack or connection attempt.

- **Description**: A half-open scan that sends TCP SYN packets to a target to check for open ports without completing the full TCP handshake.
- **Purpose**: Quick and stealthy, as it does not complete the handshake, leaving less trace in the logs.
- **How It Works**:
    - Sends a SYN packet.
    - If the port is open, the target responds with a SYN-ACK.
    - The scanner does not send the final ACK but instead sends an RST (reset) to terminate the connection.

3.15 . Stealth Description: A general term for scans designed to avoid detection by intrusion detection systems (IDS) or firewalls.

- **Techniques**: Includes SYN scans, fragmented packets, or using randomized IP addresses to mask the scan source.

3.16 XMAS

XMAS - XMAS scans send a packet with the FIN, URG, and PSH flags set. If the port is open, there is no response; but if the port is closed, the target responds with a RST/ACK packet. XMAS scans work only on target systems that follow the RFC 793 implementation of TCP/IP and don't work against any version of Windows.

- **Description**: A type of TCP scan that sets specific flags in the TCP header: FIN, URG, and PSH.
- **Purpose**: Detects closed ports based on responses or lack thereof. It is named "XMAS" because the packet is "lit up" with flags like a Christmas tree.
- **How It Works**:
  - Sends a TCP packet with these flags set.
  - No response indicates an open port (on systems compliant with RFC 793), while RST indicates a closed port.

3.17 NULL

**NULL -** A NULL scan is also similar to XMAS and FIN in its limitations and response, but it just sends a packet with no flags set.

- **Description**: A TCP scan where no flags are set in the TCP header.
- **Purpose**: Similar to XMAS scans, it checks for responses to identify open or closed ports.
- **How It Works**:
  - Sends a TCP packet with no flags.
  - No response implies an open port (on systems compliant with RFC 793), while RST indicates a closed port.

3.18 IDLE Scan

**IDLE -** An IDLE scan uses a spoofed IP address to send a SYN packet to a target. Depending on the response, the port can be determined to be open or closed. IDLE scans determine port scan response by monitoring IP header sequence numbers.

- **Description**: A highly stealthy scan that uses a third-party "zombie" host to conduct the scan.
- **Purpose**: Obscures the scanner's IP address by making the target believe the zombie is the scanner.
- **How It Works**:
  - Uses the IP ID sequence of the zombie to infer responses.
  - Sends spoofed packets appearing to come from the zombie.
  - Observes changes in the zombie's IP ID sequence to determine port status.

3.19 FIN

**FIN -** A FIN scan is similar to an XMAS scan but sends a packet with just the FIN flag set. FIN scans receive the same response and have the same limitations as XMAS scans. FIN A FIN scan is similar

to an XMAS scan but sends a packet with just the FIN flag set. FIN scans receive the same response and have the same limitations as XMAS scans.

- **Description**: A TCP scan that sends a packet with only the FIN flag set.
- **Purpose**: Bypasses some firewalls and IDS systems, especially if they are configured to monitor SYN packets.
- **How It Works**:
  - Sends a FIN packet.
  - No response means the port is open; RST means it's closed.

### Use Cases and Considerations

- These scans are used by network administrators for security assessments or by attackers for reconnaissance.
- **Stealth Techniques**: Stealthy scans like SYN, IDLE, or FIN are less likely to trigger alarms in IDS but may still be detected by modern security systems.
- **Limitations**: Some techniques, like XMAS and NULL scans, are less effective against Windows systems, as they do not strictly adhere to RFC 793.

IPEye is a TCP port scanner that can do SYN, FIN, Null, and XMAS scans. It's a commandline tool. IPEye probes the ports on a target system and responds with closed, reject, drop, or open. Closed means there is a computer on the other end, but it doesn't listen at the port. Reject means a firewall is rejecting the connection to the port (sending a reset back). Drop means a firewall is dropping everything to the port, or there is no computer on the other end. Open means some kind of service is listening at the port. These responses help a hacker identify what type of system is responding.

IPSecScan is a tool that can scan either a single IP address or a range of addresses looking for systems that are IPSec enabled.

NetScan Tools Pro, hping2, KingPingicmpenum, and SNMP Scanner are all scanning tools and can also be used to fingerprint the operating system (discussed later).

Icmpenum uses not only ICMP Echo packets to probe networks, but also ICMP Timestamp and ICMP Information packets. Furthermore, it supports spoofing and sniffing for reply packets. Icmpenum is great for scanning networks when the firewall blocks ICMP Echo packets but fails to block Timestamp or Information packets.

The hping2 tool is notable because it contains a host of other features besides OS fingerprinting such as TCP, User Datagram Protocol (UDP), ICMP, and raw-IP ping protocols, traceroute mode, and the ability to send files between the source and target system.

SNMP Scanner allows you to scan a range or list of hosts performing ping, DNS, and Simple Network Management Protocol (SNMP) queries.

### 3.20 Banner grabbing

Banner grabbing is a method used by attackers and security teams to obtain information about network computer systems and services running on open ports. A banner is a text displayed by a host that provides details such as the type and version of software running on the system or server. The screen displays the software version number on the network server and other system information, giving cybercriminals an advantage in cyber attacks. Banner grabbing considers collecting software banner information such as name and version. Hackers can use the OSINT tool to get the banners manually or automatically. Banner capture is one of the essential steps in both offensive and defensive penetration testing environments.

**Types of Banner Grabbing:**

1. **Active Banner Grabbing**: In this method, Hackers send packets to a remote server and analyze the response data. The attack involves opening a TCP or similar connection between the origin and the remote server. An Intrusion Detection System (IDS) can easily detect an active banner.

2. **Passive Banner Capture**: This method allows hackers and security analysts to get the same information while avoiding disclosing the original connection. In passive banner grabbing, the attackers deploy software and malware as a gateway to prevent direct connection when collecting data from the target. This technique uses third-party network tools and services to capture and analyze packets to identify the software and version being used. run on the server.

**Usage:**

Hackers can perform a banner-grabbing attack against various protocols to discover insecure and vulnerable applications and exploits. There are many services, protocols, and types of banner information that you can collect using banner grabbing. You can develop various methods and tools for the discovery process. In general, banner grab allows an attacker to discover network servers and services running along with their instances on open ports, as well as the operating system. Given the type and version of an application, a hacker, or pen tester, can quickly scan for known and exploitable vulnerabilities in that version.

**Service Ports:**

- Port 80 is running on Hypertext Transfer Protocol (HTTP) service.
- Port 21 is running on the File Transfer Protocol (FTP) service.
- Port 25 runs on the Simple Mail Transfer Protocol (SMTP) service.

**Important Points:**

- Banner Grabbing is used in Ethical Hacking to gather information about a target system before launching an attack.
- In order to gather this information, the Hacker must choose a website that displays banners from affiliate sites and navigate from the banner to the site served by the affiliate website.
- Banner Grabbing can be done through manual means or through the use of automated tools such as web crawlers, which search websites and download everything on them, including banners and files.

### 3.21 OS Fingerprinting

If a hacker can determine what type of operating system a targeted computer is running, he or she can work to exploit the vulnerabilities present in that operating system. OS Fingerprinting is used by security professionals and hackers for mapping remote networks and determining which vulnerabilities might be present to exploit. In fact, it is a tactic used by cyber-criminals and even ethical hackers to figure out what type of operating system is being used by a target computer on a network. In fact, by analyzing certain protocol flags, options, and data in the packets a device sends onto the network, hackers can make relatively accurate guesses about the OS that sent those packets.

OS Fingerprinting works only for packets that contain a full-fledged TCP connection; that is the TCP connection should have a SYN, SYN/ACK, and ACK connection.

There are two Fingerprinting:

- Active
- Passive

**Active OS Fingerprinting**

Active OS fingerprinting involves actively determining a targeted PC's OS by sending carefully crafted packets to the target system and examining the TCP/IP behavior of received responses. The main reason why an attacker may prefer a passive approach is to reduce the risk of being caught by an IDS, IPS, or a firewall. Properly configured, implemented, and maintained IDSes, IPSes, and firewalls can mitigate active fingerprinting. In other words, active fingerprinting is challenging the target machine to see what happens.

Active fingerprinting works by sending packets to a target and analyzing the packets that are sent back. Almost all active fingerprinting these days is done with Nmap.

Nmap is usually used by network administrators to monitor the security of their networks. In fact, Nmap is an effective application for both admins and attackers. Nmap sends probes to lots of different TCP/IP ports, and analyzes what returned. Nmap utilizes scripting that analyzes that data to print out results that are useful for OS fingerprinting. Running an OS fingerprinting scan in Nmap is as simple as typing:

"nmap -A ip_address_or_domain_name_of_target". Source: infosecinstitute.com

**Passive OS Fingerprinting**

Passive OS fingerprinting is a more effective way of avoiding detection or being stopped by a firewall and it examines of passively collected sample of packets from a host. Passive fingerprinting uses a pcap (packet capture) API. In GNU/Linux and BSD/Unix operating systems, pcap can be found in the libpcap library, and for Windows, there's a port of libpcap called WinPcap. Passive fingerprinting can make a guess of a target's OS, because different OSes have different TCP/IP implementations.

Passive OS fingerprinting is less accurate than active OS fingerprinting, but may be a technique chosen by an attacker or penetration tester who wants to avoid detection. Passive fingerprinting can be mitigated by assuring that NICs (network interface cards) don't operate in promiscuous mode.

There are following four important elements that we will look at to determine the operating system

- **TTL**: What the operating system sets the Time-To-Live on the outbound packet.
- **Window Size**: What the operating system sets the Window Size at.
- **DF**: Does the operating system set the Don't Fragment bit?
- **TOS**: Does the operating system set the type of Service?

Source: zerosuniverse.com and infosecinstitute.com

**Tools Used for OS Fingerprinting**

**P0f – passive**: This tool is an OS Fingerprinting tool that utilizes an array of sophisticated, purely passive traffic fingerprinting mechanisms to identify the players behind any incidental TCP/IP communications (often as little as a single normal SYN) without interfering in any way.

Website: http://lcamtuf.coredump.cx/p0f3/

**Ettercap – passive**: This tool is a comprehensive suite for man in the middle attacks. It features sniffing of live connections, content filtering on the fly and many other interesting tricks. It supports active and passive dissection of many protocols.

Website: http://ettercap.github.io/ettercap/

**XProbe2 – active**: This tool is an active OS Fingerprinting tool with a different approach to operating system fingerprinting. Xprobe2 relies on fuzzy signature matching, probabilistic guesses and multiple simultaneous matches, and a signature database.